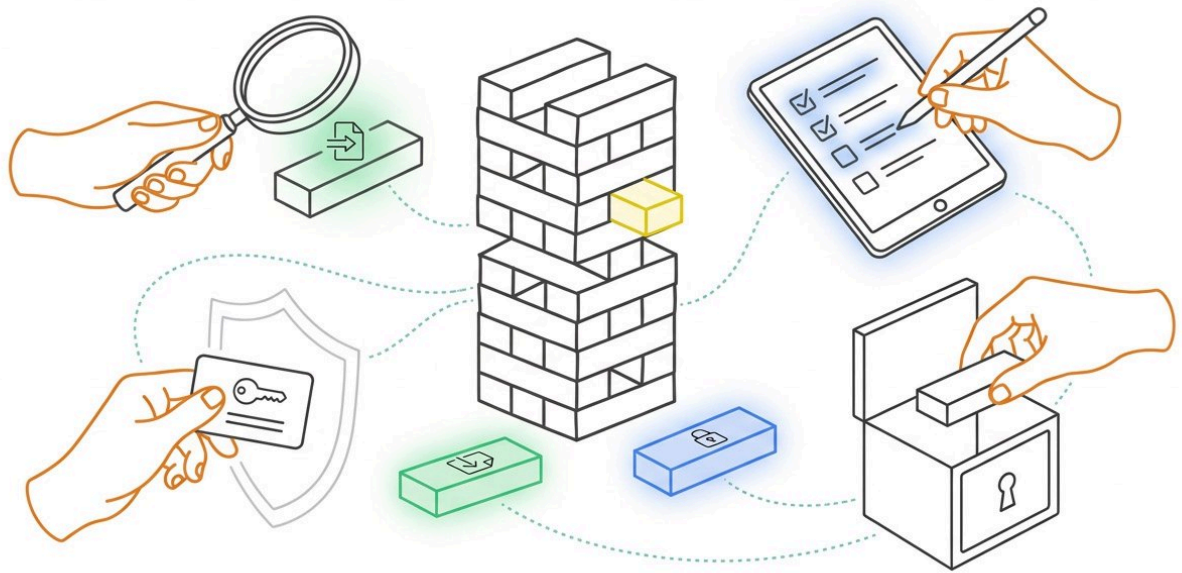


ANÈL HENNING

COMPLIANCE ANALYST

Keeping You Compliant!



THE LOGICAL CODERS AUDIT TEMPLATE PACKAGE

Twelve templates, shown working

Each template is explained in plain language, completed with a fictional healthcare client, and tied to a real case where the process failed.

Logical **Coders**

HOW TO READ THIS BOOK

I am a Compliance Coordinator at Logical Coders in South Tampa, where I research governance, risk and compliance requirements for HIPAA clients. I graduate from Purdue Global with an MS in Cybersecurity Management in November 2026, and I bring more than twenty years of graphic design and production discipline to compliance work.

Every illustration in this book is my own. Each template page reads the same way:

- 1 **The concept** — an illustration and the process, step by step.
- 2 **The template in action** — completed for Sunshine Dental Group, a fictional 22-person practice, with numbered callouts.
- 3 **When it fails** — a real case where that step broke down.



Evidence must be both sufficient and appropriate, and it gets stronger when it comes directly from a system instead of someone's memory.

Paraphrasing the Public Company Accounting Oversight Board (PCAOB, n.d.-c)

KEY IT AUDITING DEFINITIONS

IT audit

A structured review of systems, processes and controls to confirm they protect information and work as intended.

Control

An action, process or technology safeguard that reduces risk.

Design vs. operating effectiveness

Whether a control is designed to address a risk, and whether it worked consistently all period.

Exception and finding

Evidence that missed a requirement; a finding documents issue, criteria, cause, risk and action.

Audit criteria

The requirement used to judge performance: HIPAA, NIST, contracts, policies or procedures.

Audit evidence

Reliable information that supports a conclusion: reports, approvals, tickets, logs, records.

Population and sample

The complete set of records, and the smaller group selected for testing.

Inherent and residual risk

Risk before controls, and the risk that remains after treatment.

EVIDENCE-HANDLING RULE

Printed on every template: no ePHI, passwords, private keys, full Social Security numbers or unnecessary screenshots in workpapers. Use the minimum necessary, redact, restrict access, store in an approved repository.

THE TEMPLATE PACKAGE AT A GLANCE

Twelve templates that take an audit from planning to a decision leadership can sign.



CAPTION *How Logical Coders manages the cybersecurity and IT audit lifecycle (2026)*

PLAN

01 Audit Program	4
02 Audit Plan	5

CONTROL

04 Control Narrative	7
09 Account Lifecycle Review	12

DECISION

07 Audit Tracker Report	10
11 HIPAA Governance Report	14
12 Compliance Document Package	15

EVIDENCE

03 Fieldwork Support Packet	6
08 Operating Effectiveness Report	11
10 Audit Log Summary	13

RISK

05 Risk Register Assessment	8
06 Gap Analysis Report	9

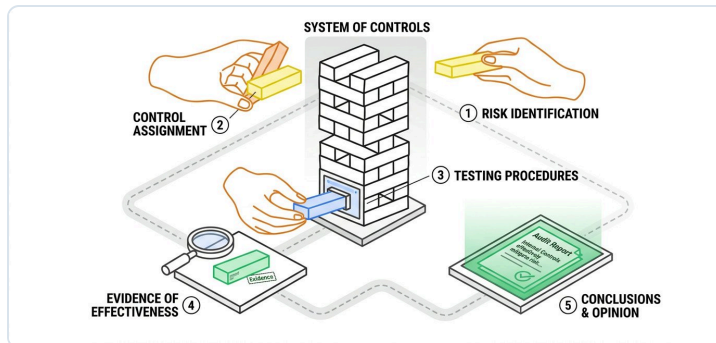
ALSO IN THIS BOOK

How to read this book · 02
References · 16

AUDIT PROGRAM

Risk-to-control audit planning

Definition. The auditor's detailed testing guide. It connects each risk to a control objective, the criteria, a test procedure, the evidence, a sample and a conclusion.



CAPTION *The System of Controls (2026)*

HOW IT WORKS

- 1 **Risk identification** asks what could go wrong.
- 2 **Control assignment** matches each risk to a control that addresses it.
- 3 **Testing procedures** check whether each control works.
- 4 **Evidence of effectiveness** collects proof of the test results.
- 5 **Conclusion and opinion** decides and reports.

TEMPLATE IN ACTION

Completed sample · Sunshine Dental Group (fictional data)

AUDIT PROGRAM

AP-2026-01 · v1.0

Audit name **HIPAA Security Rule readiness audit** 1

Objective **Do access, risk and logging controls protect ePHI?** 2

Scope **Cloud EHR, email, patient portal** Audit period **Apr 1 – Jun 30, 2026**

AUDIT CRITERIA 3

☒ HIPAA Security Rule ☒ NIST SP 800-53 ☒ Org. policies ☐ Contract

RISK → CONTROL → TEST 4

Risk	Control	Test procedure	Evidence	Status
R-04 Phishing	AC-2	Re-perform account review	Roster + EHR export	Tested
R-01 Ransomware	RA-3	Inspect risk register	Register v1.0	Tested
Undetected access	AU-6	Inspect log reviews	EHR log, May 2026	Ineffective

OVERALL CONCLUSION 5

☐ Effective ☒ Needs improvement ☐ Ineffective ☐ Not tested

Prepared **Anèl Henning** Approved **Dentist-Owner (pending)**

READ THE CALLOUTS

- 1 **Name the audit** so every workpaper traces back to it.
- 2 **One-sentence objective:** what the audit will decide.
- 3 **Criteria are the yardstick** every finding cites.
- 4 **Each row links** a risk to its control, test and proof.
- 5 **Fixed conclusion choices** keep results comparable.

WHEN IT FAILS

§ 404

Sarbanes-Oxley, 2002

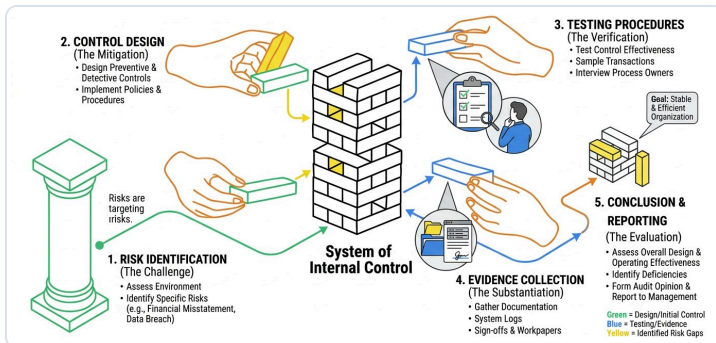
Enron and WorldCom made this five-step audit law

After the Enron and WorldCom accounting scandals, Congress passed the Sarbanes-Oxley Act. Section 404 requires management to assess internal control over financial reporting, and larger companies need an outside auditor to report on it — find the risks, map the controls, test them, keep the evidence and give an opinion (PCAOB, n.d.-a; Sarbanes-Oxley Act, 2002).

AUDIT PLAN

The risk and control lifecycle

Definition. How the audit will be completed: objective, scope, people involved, timeline, evidence needs, testing approach, communication and final deliverables (ISACA, 2022).



CAPTION Comprehensive Risk & Control Lifecycle (2026)

HOW IT WORKS

- 1 Risk identification** names specific risks, such as a data breach.
- 2 Control design** adds preventive controls that stop problems and detective controls that find them.
- 3 Testing** checks controls, transactions and interviews owners.
- 4 Evidence collection** gathers documents, logs and sign-offs.
- 5 Reporting** judges design and operation and lists deficiencies (COSO, 2013).

TEMPLATE IN ACTION

Completed sample · Sunshine Dental Group (fictional data)

AUDIT PLAN

PLAN-2026-01 · v1.0

Audit sponsor **Dentist-Owner** **1**

Audit lead **Anèl Henning**

Period reviewed **Q2 2026**

Report audience **Dentist-Owner**

3 · STAKEHOLDERS **2**

Name / role	Responsibility	ePHI?
Office Manager	Control owner: access, training	Yes
IT Vendor	System owner: EHR, email, backups	Yes · BAA missing
Dentist-Owner	Sponsor, approver	Yes

4 · AUDIT SCHEDULE **3**

Phase	Activity	Owner	Due	Status
1	Kickoff, evidence requests	Audit lead	Week 1	Done
2	Fieldwork and testing	Audit lead	Week 2–3	Done
3	Draft report, management response	Sponsor	Week 4	Open

5 · EVIDENCE-REQUEST PROTOCOL **4**

☒ Encryption required ☒ ePHI only if necessary and approved

☒ Redaction required

Escalation **Dentist-Owner** **5**

Weekly status **Fridays**

READ THE CALLOUTS

- 1 Sponsor owns the decision;** the lead owns the work.
- 2 Stakeholders flag ePHI** and missing agreements early.
- 3 Every phase** has an owner, a due date and a status.
- 4 The protocol is set** before the first request goes out.
- 5 Escalation is agreed** before anything goes wrong.

WHEN IT FAILS

\$3.8B

misstated expenses

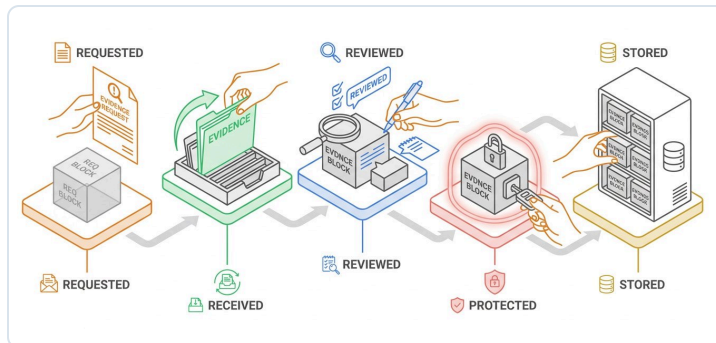
WorldCom: internal audit traced entries to their support

In 2002, Cynthia Cooper's internal audit team found that WorldCom had recorded about \$3.8 billion of ordinary expenses as capital assets, making profits look larger. They found it by tracing entries back to their support and asking the people involved to explain them — steps 3 through 5 of the lifecycle (Cooper, 2008).

FIELDWORK SUPPORT PACKET

The audit evidence journey

Definition. The central record for collecting, tracking and protecting audit evidence, so every item is complete, relevant, reliable, traceable and stored securely.



CAPTION Audit Evidence Journey (2026)

HOW IT WORKS

- 1 **Requested:** a written request says exactly what is needed.
- 2 **Received** from the control owner through the approved repository.
- 3 **Reviewed** for completeness, accuracy and relevance to the control.
- 4 **Protected** so only approved people can see or change it.
- 5 **Stored** for as long as rules require — six years under HIPAA (§ 164.316).

TEMPLATE IN ACTION

Completed sample · Sunshine Dental Group (fictional data)

FIELDWORK SUPPORT PACKET

FSP-2026-01 · v1.2

A · EVIDENCE REQUEST LIST 1

ID	Item	Control	Owner	Received	Accepted
REQ-01	Staff roster (HR)	AC-2	Office Mgr	✓	✓
REQ-02	EHR account export	AC-2	IT Vendor	✓	✓
REQ-04	EHR audit log, May	AU-6	IT Vendor	✗	Not generated
REQ-05	Signed BAAs	§ 164.308(b)	Owner	✗	None on file

B · ACCEPTANCE CHECKLIST, REQ-02 2

- ☒ Right system ☒ In audit period ☒ Performer named
- ☒ Complete, traceable ☒ Sensitive data minimized
- ☒ Source and date logged ☒ In approved repository

C · INTERVIEW RECORD 3

Interviewee Office Manager · termination process

Summary Disable requests go to IT by email; no same-day step → G-04 4

READ THE CALLOUTS

- 1 **Every request has an ID** that the workpapers cite.
- 2 **Received is not accepted.** Acceptance runs all seven checks.
- 3 **Interviews are recorded** word for word, then backed by records.
- 4 **Missing evidence becomes a finding**, not a hole in the file.

WHEN IT FAILS

2005

Supreme Court ruling

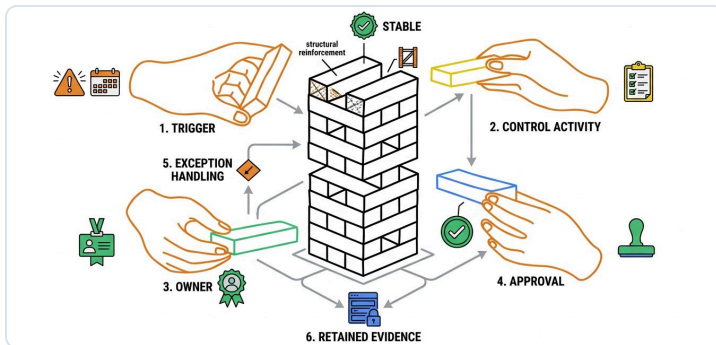
Arthur Andersen destroyed Enron's audit documents

As investigations began in 2001, Enron's audit firm destroyed large amounts of documents. Andersen was convicted of obstruction; the Supreme Court overturned the verdict over jury instructions, but the firm had already collapsed (Arthur Andersen LLP v. United States, 2005). Sarbanes-Oxley then made destroying audit records a crime (Sarbanes-Oxley Act, 2002).

CONTROL NARRATIVE

The parts of a control

Definition. Explains how a control works in practice: its owner, trigger, timing, actions, systems, evidence, exceptions, escalation and retention location.



CAPTION *The Parts of a Control (2026)*

HOW IT WORKS

- 1 **Trigger:** the event or date that starts the control.
- 2 **Activity and owner:** the task itself and the person who does it.
- 3 **Approval:** a second person signs off that it was done correctly.
- 4 **Exception handling:** what happens when it does not go as planned.
- 5 **Retained evidence:** the ticket or report that proves it happened (COSO, 2013).

TEMPLATE IN ACTION

Completed sample · Sunshine Dental Group (fictional data)

CONTROL NARRATIVE

CN-AC-2 · v2.0

Control **AC-2 Account Management** Owner **Office Manager**

Objective **Only approved staff have EHR and email accounts; access is removed at termination or role change**

☒ Preventive ☒ Detective ☐ Manual ☐ Automated ☒ Hybrid
☐ Corrective

CONTROL NARRATIVE

- 1 Trigger **Hire, role change, exit** 1
 - 2 Frequency **Event + quarterly**
 - 3 Performer **Office Manager** 2
 - 4 Reviewer **Dentist-Owner** 3
 - 5 Procedure **Request form → owner approval → least-privilege setup → logged**
 - 7 Evidence **Signed request, disable ticket with timestamp, quarterly script output** 4
 - 8 Exceptions **Logged to the Audit Tracker; escalated to Dentist-Owner** 5
 - 10 Retention **Approved repository · six years** 6
- ☒ Access control ☒ Authentication ☒ AC ☒ IA ☐ AU ☐ RA
☐ Audit controls

READ THE CALLOUTS

- 1 **Trigger** — when the control starts.
- 2 **Owner** — one named person does the work.
- 3 **Approval** — a second person signs off.
- 4 **Evidence** — what an auditor will ask to see.
- 5 **Exceptions** — where failures go, and to whom.
- 6 **Retention** — where proof lives, and for how long.

WHEN IT FAILS

145M

people affected

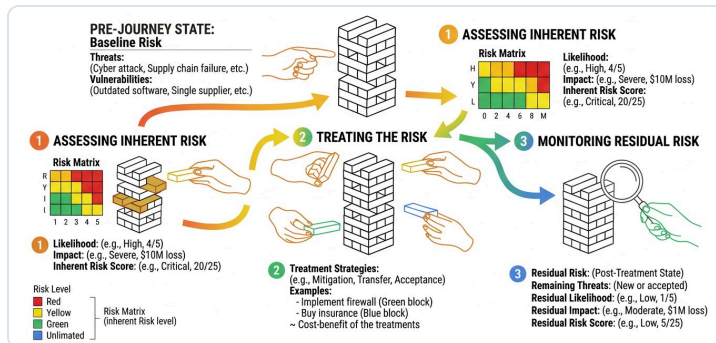
Equifax 2017: the trigger fired, every other part failed

A public alert warned of an Apache Struts flaw in March 2017. Equifax's internal alert never reached the system owner, a later scan missed the system, and the patch was never applied. Attackers stole data on 145 million people from May to July (U.S. Government Accountability Office [GAO], 2018).

RISK REGISTER ASSESSMENT

Inherent risk, treatment and residual risk

Definition. Identifies, prioritizes, treats and monitors risks. It records the risk before controls and the risk that remains after treatment.



HOW IT WORKS

- 1 Assess inherent risk** before controls: likelihood × impact on a 1–5 scale.
- 2 Treat it:** mitigate, transfer, avoid or accept, weighing cost against benefit.
- 3 Monitor residual risk**, because new threats can raise it again (NIST, 2012).

CAPTION *Inherent Risk, Treatment and Residual Risk (2026)*

TEMPLATE IN ACTION

Completed sample · Sunshine Dental Group (fictional data)

RISK REGISTER ASSESSMENT

RR-2026-01 · v1.0

Scoring model **Likelihood × Impact, 1–5** **1** Assessment owner **IT Vendor**

Risk	Threat · weakness	Existing	Inherent	Treatment · owner	Residual
R-01 EHR	Ransomware · patching, restore tests incomplete	Vendor backups	20	Patch, test restore · IT Vendor · Day 30	10
R-03 Devices	Lost device · no MDM or encryption	None	20	Enroll in MDM, encrypt · Office Mgr · Day 30	8
R-04 Email	Phishing · no training 3+ yrs, MFA partial	Spam filter	15	MFA, train all 22 staff · Office Mgr · Day 45	6

Inherent **2** Treatment **3** Residual, projected **4**

RISK-TREATMENT DECISION

☒ **Mitigate (all three)** ☐ Transfer ☐ Avoid ☐ Accept

Approving executive **Dentist-Owner (pending)** **5**

READ THE CALLOUTS

- 1 Score = likelihood × impact**, rated before any controls.
- 2 Inherent scores 15–25** are Critical and go first.
- 3 Every treatment** names an owner and a target date.
- 4 Residual is a projection** until the fix is retested.
- 5 Accepting risk** needs an approving executive.

WHEN IT FAILS

\$1.4B

insurance claim

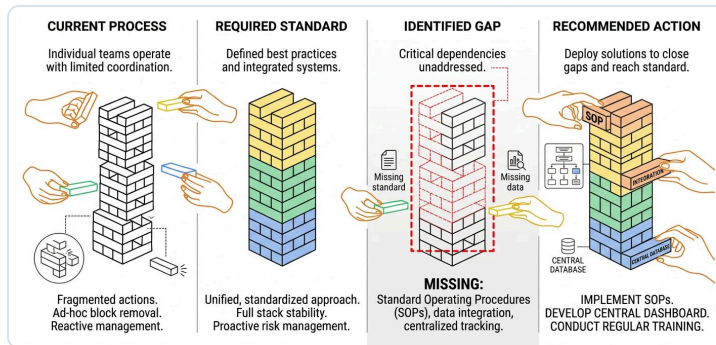
Merck and NotPetya: transferring risk depends on the wording

NotPetya damaged thousands of Merck's computers in 2017. Merck claimed \$1.4 billion under its property policy; insurers refused, citing a war exclusion. A New Jersey appeals court ruled for Merck in 2023 — insurance can transfer risk, but the exact policy language decides it (Merck & Co. v. ACE American Insurance Co., 2023).

GAP ANALYSIS REPORT

Current state against the required standard

Definition. Compares the current state with a requirement and turns the difference into a practical, risk-based recommendation.



HOW IT WORKS

- 1 Current process:** how work is done today.
- 2 Required standard:** defined practices and connected systems.
- 3 Identified gap:** the missing pieces — procedures, data, tracking.
- 4 Recommended action:** how to close it. CSF 2.0 compares a Current Profile with a Target Profile the same way (NIST, 2024).

CAPTION Risk Management Journey: Gap Analysis (2026)

TEMPLATE IN ACTION

Completed sample · Sunshine Dental Group (fictional data)

GAP ANALYSIS REPORT

GAP-2026-01 · v1.0

Area **Audit controls · cloud EHR**

Assessed **May 2026 · A. Henning**

Requirement	Reference	Current state	Risk	Recommendation
Log creation	§ 164.312(b)	Logging not enabled	High	Enable on all ePHI systems
Log review	§ 164.308(a)(1)(ii)(D)	No reviewer assigned	High	Assign reviewer; weekly
Escalation	IR plan	No procedure	Medium	Add steps to IR plan

Each row cites its requirement **1**

FINDING STATEMENT · F-03

Condition **EHR audit logging is off and no one reviews activity** **2**

Criteria **HIPAA audit controls, § 164.312(b)** **3**

Risk **Improper ePHI access would go undetected** **4**

Recommendation **Enable logging; assign a weekly reviewer**

Owner · due **IT Vendor · Day 30**

Mgmt response **[PENDING]** **5**

READ THE CALLOUTS

- 1 Every row cites** the HIPAA or NIST requirement.
- 2 Condition** — what the auditor actually saw.
- 3 Criteria** — what should be in place.
- 4 Risk** — why the gap matters to the business.
- 5 Management response** turns a finding into a commitment.

WHEN IT FAILS

\$6.85M

HHS settlement

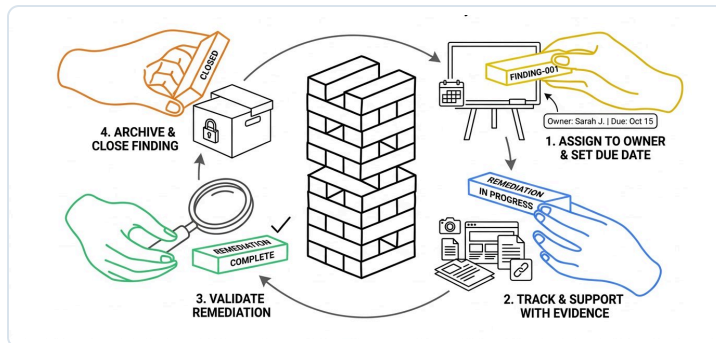
Premera Blue Cross: a gap no one measured

Attackers entered Premera through a phishing email in 2014 and went unnoticed for nearly a year, exposing data on more than 10.4 million people. HHS found Premera had not done an enterprise-wide risk analysis — the HIPAA step designed to find these gaps (U.S. Department of Health and Human Services [HHS], 2020).

AUDIT TRACKER REPORT

Remediation and validation cycle

Definition. The central status record for requests, testing tasks, findings, actions, evidence, owners, deadlines and closure validation.



HOW IT WORKS

- 1 **Assign** the finding to one owner with a due date.
- 2 **Track** progress and collect evidence: tickets, updates, screenshots.
- 3 **Validate** that the problem is actually solved, not just marked done.
- 4 **Archive and close** the finding as a permanent record (NIST, 2020).

CAPTION Risk Remediation and Validation Cycle (2026)

TEMPLATE IN ACTION

Completed sample · Sunshine Dental Group (fictional data)

AUDIT TRACKER REPORT

TRK-2026-01 · Day 1

Reporting date **Day 1 of 90-day plan**

Status ☐ On track ☒ **At risk**
☐ Delayed

ID	Description	Risk	Owner	Due	Status
G-01	No BAAs on file	High	Dentist-Owner	Day 7	Not started
G-02	MFA off on EHR, email, portal	Critical	IT Vendor	Day 14	In progress
G-03	EHR audit logging off	High	IT Vendor	Day 30	Not started
G-04	Leaver disabled 19 days late	High	Office Mgr	Day 21	Not started
G-05	Shared front-desk login	High	Office Mgr	Day 21	Not started

One owner each 1 Dated 2

STATUS DEFINITIONS 3

Pending validation **Fix done; waiting for an independent retest**

Closed **Retest passed and evidence filed in the repository**

Escalation **G-01 and G-02 to Dentist-Owner at weekly status 4**

READ THE CALLOUTS

- 1 **One accountable owner** per item, never a team.
- 2 **Due dates** come from the gap analysis and risk score.
- 3 **"Pending validation"** keeps done and verified apart.
- 4 **Escalations** put blocked items in front of leadership.

WHEN IT FAILS

\$95M

OCC + SEC penalties

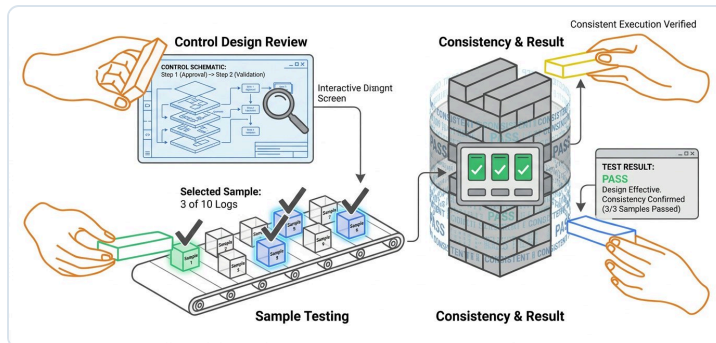
Morgan Stanley: marked done, never validated

Closing two data centers in 2016, the firm hired a vendor to destroy devices holding customer data but did not oversee the work (Office of the Comptroller of the Currency [OCC], 2020b). Some devices were resold with data still on them. The OCC fined it \$60 million and the SEC added \$35 million (U.S. Securities and Exchange Commission [SEC], 2022).

OPERATING EFFECTIVENESS REPORT

Control design review and sample testing

Definition. Documents whether a control was designed adequately and operated consistently during the audit period, based on defined test procedures and samples.



CAPTION Control Design Review (2026)

HOW IT WORKS

- 1 Design review:** read how the control should work and decide if it can stop the risk.
- 2 Sample testing:** check a sample of items against each attribute.
- 3 Consistency and result:** record whether it worked every time. Sampling lets the auditor conclude about the whole group (PCAOB, n.d.-b).

TEMPLATE IN ACTION

Completed sample · Sunshine Dental Group (fictional data)

OPERATING EFFECTIVENESS REPORT

OE-AC-2 · Apr 2026

Control **AC-2 Account Management**

Tester **Anèl Henning**

Population **8 EHR accounts · 5 roster entries**

1 Method ☒ **Full population** **2**

Attribute tested	Evidence	Result
Leavers disabled within 1 day	Roster vs. export	1 exception · E-1017, 19 days
No shared or unassigned accounts	Account export	1 exception · FRONTDESK
MFA on every active account	Account export	4 exceptions
Access reviewed in 12 months	Review log	1 exception · FRONTDESK

Re-performed in Python and SQL from raw data **3**

Testing result ☐ Effective ☐ With exceptions ☒ **Ineffective**

Exceptions **7 across 4 attributes** **4**

Root cause **No same-day disable step; shared login; MFA rollout incomplete**

Retest required **Yes · after G-02, G-04, G-05** **5** Reviewer **[REVIEWER]**

READ THE CALLOUTS

- 1 The population is fixed** before anything is sampled.
- 2 The sample method** is declared, never implied.
- 3 Re-performance** beats asking the owner if it worked.
- 4 Exceptions get a root cause**, not just a count.
- 5 Retest** ties back to tracker items.

WHEN IT FAILS

\$460M

lost in 45 minutes

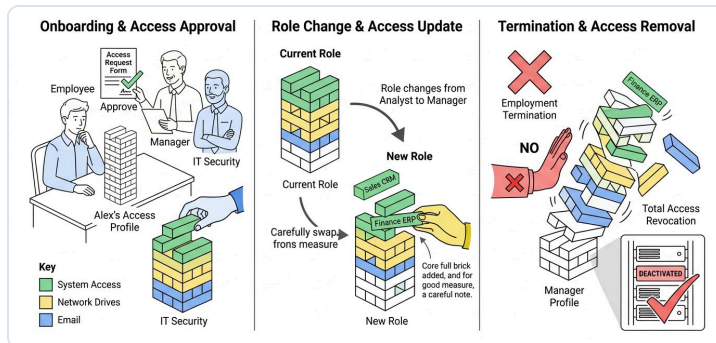
Knight Capital: the design review that never happened

In August 2012 a technician copied new trading code to seven of eight servers. The eighth ran old code and sent millions of unintended orders in 45 minutes. The SEC found no written procedure requiring a second person to review deployments — a design review would have flagged it before any sample was tested (SEC, 2013).

ACCOUNT LIFECYCLE REVIEW

Joiner, mover, leaver — stability through stewardship

Definition. Tests whether joiner, mover, leaver, contractor, shared, service and privileged access is approved, timely, appropriate and regularly reviewed.



HOW IT WORKS

- 1 Joiner:** access is requested, approved and set up before day one.
- 2 Mover:** new access is added and old access removed.
- 3 Leaver:** every account is disabled on the last day.
- 4 Recertification:** managers confirm who still needs access (NIST, 2020).

CAPTION Access Management Journey (2026)

TEMPLATE IN ACTION

Completed sample · Sunshine Dental Group (fictional data)

ACCOUNT LIFECYCLE REVIEW

ALR-2026-Q2 · v1.0

Review period **Apr 2026**

Sources **HR roster vs. EHR export**

1

Review	Account	Test	Result
Joiner	E-1021	Approved before start; MFA	Pass
Mover	E-1008	Front desk → billing; old access removed	Pass
Leaver	E-1015	Terminated Apr 3; disabled Apr 3	Pass · 0 days
Leaver	E-1017	Terminated Apr 8; disabled Apr 27	Exception · 19 days
Privileged	FRONTDESK	Shared by several staff	Exception · shared
Privileged	VENDOR-IT	Remote vendor account	Pass · no BAA

Joiner and mover **2** Days to disable **3** Privileged, separately **4**

Records reviewed **8** High-risk exceptions **2**

Corrective actions **Same-day disable step (G-04); individual accounts (G-05)**

Conclusion **Needs improvement** **5**

READ THE CALLOUTS

- 1 Two independent sources:** HR says who left, IT says who has access.
- 2 Joiners and movers** are tested for approval and least privilege.
- 3 Leavers are measured** in days, against a 1-day standard.
- 4 Shared and vendor accounts** get their own review.
- 5 The conclusion** feeds the governance report.

WHEN IT FAILS

8.2M

customers exposed

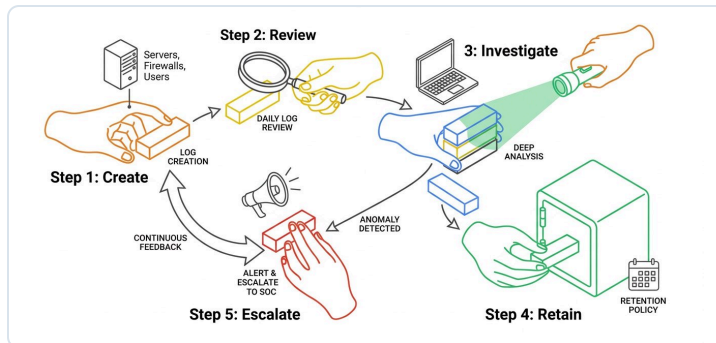
Cash App: a former employee kept access

In 2022, Block reported that a former employee downloaded reports with information on about 8.2 million Cash App Investing customers after their job ended. The reports were part of their old role, but the access was never removed (Block, Inc., 2022). A leaver test compares exactly these two lists.

AUDIT LOG SUMMARY

The security logs lifecycle

Definition. Evaluates whether critical systems create, protect, retain, review and investigate logs that support detection, investigation and audit readiness.



CAPTION Security Logs Lifecycle (2026)

HOW IT WORKS

- 1 **Create:** servers, firewalls and user activity produce records.
- 2 **Review:** a person or tool checks them on a schedule.
- 3 **Investigate** any suspicious event more closely.
- 4 **Retain** logs securely for the required time.
- 5 **Escalate** confirmed problems and feed lessons back.

TEMPLATE IN ACTION

Completed sample · Sunshine Dental Group (fictional data)

AUDIT LOG SUMMARY

ALS-EHR · May 2026

System **Cloud EHR · IT Vendor**

Review period **May 2026**

Log sources ☒ **Application** ☒ **IAM / SSO** ☐ Firewall ☐ EDR **1**

Review area	Expected	Observed	Gap
Creation	Logins, ePHI access, exports logged	Logging not enabled	Gap
Review	Named reviewer, set schedule	No reviewer assigned	Gap
Retention	Kept per written policy	No period defined	Gap
Escalation	Named contact	No procedure	Gap

KEY EVENTS TESTED **2**

☐ Logins ☐ Privileged activity ☐ ePHI access ☐ Data exports
☐ Account changes ☐ Config changes

None could be tested — no logs were generated **3**

Reviewer **[UNASSIGNED]**

Frequency **Weekly, recommended**

Conclusion **Ineffective · tracked as G-03** **4**

READ THE CALLOUTS

- 1 **Name the log sources** before judging them.
- 2 **Eight key event types** are tested, not assumed.
- 3 **An untestable control** is recorded as a result in itself.
- 4 **The conclusion** opens a tracker item automatically.

WHEN IT FAILS

40M

cards stolen

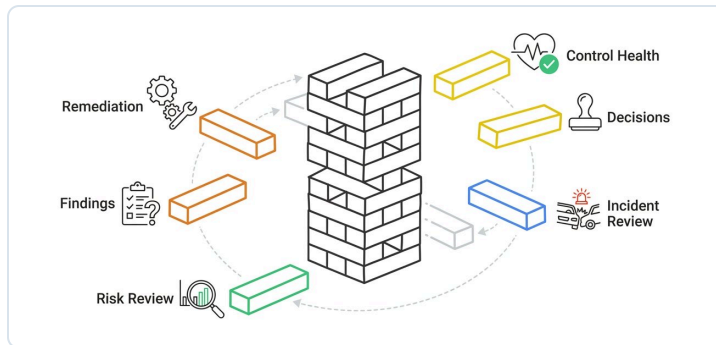
Target 2013: the alerts fired, no one escalated

Attackers entered Target's network with credentials stolen from a heating and air-conditioning vendor and placed malware on checkout systems. Security tools raised alerts, but they were not acted on in time, and card data for about 40 million customers was stolen (U.S. Senate Committee on Commerce, Science, and Transportation, 2014).

HIPAA GOVERNANCE REPORT

Governance reporting for leadership

Definition. Gives leadership a concise view of cybersecurity and compliance risk, control health, open findings, incidents, resources and decisions requiring approval.



CAPTION Risk Management Journey: Governance Reporting (2026)

HOW IT WORKS

- 1 **Risk review:** the top risks and whether they are rising or falling.
- 2 **Findings and remediation:** what is open and how fixes are going.
- 3 **Control health:** which controls work and which fail.
- 4 **Decisions:** what needs leadership approval. CSF 2.0 places this under Govern (NIST, 2024).

TEMPLATE IN ACTION

Completed sample · Sunshine Dental Group (fictional data)

HIPAA GOVERNANCE REPORT

Prepared for **Dentist-Owner** Posture **Red** improving **1**

2 · RISK DASHBOARD

R-01 Ransomware 20

R-03 Devices 20

R-04 Phishing 15

2

3 · CONTROL HEALTH **3**

Access mgmt Red	Audit logging Red	Awareness Red
Vendor / BA Red	Backup Yellow	Incident resp. Yellow

KEY FINDINGS

Terminated user active 19 days · shared front-desk login · MFA missing on 4 accounts · EHR logging off · no BAAs on file

6 · LEADERSHIP DECISIONS REQUESTED **4**

☐ Name a security official
 ☐ Approve risk treatments
 ☐ Fund MDM and MFA
 ☐ Sign vendor BAAs

Prepared **Anèl Henning**

Approved **Dentist-Owner (pending)** **5**

READ THE CALLOUTS

- 1 **One posture word** plus a direction leaders can act on.
- 2 **Top risks** come straight from the risk register.
- 3 **Health** always pairs color with its word.
- 4 **Decisions** are boxes to tick, not paragraphs to parse.
- 5 **Approval** closes the governance loop.

WHEN IT FAILS

\$35M

SEC penalty

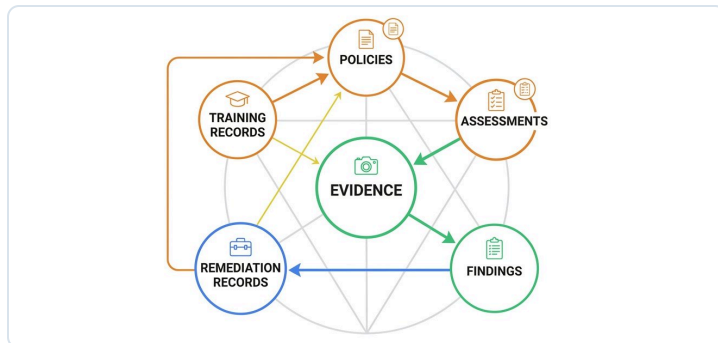
Yahoo: the breach never reached decision makers

Yahoo's security staff learned of a 2014 breach of more than 500 million accounts, but investors were not told for about two years. The SEC found managers and lawyers had not properly assessed disclosure, and the company, by then Altaba, paid \$35 million (SEC, 2018). A regular incident review would have surfaced it sooner.

COMPLIANCE DOCUMENT PACKAGE

Compliance evidence and document control

Definition. A controlled inventory of policies, assessments, evidence, training records, findings, remediation plans and reviews needed for audit readiness.



CAPTION *Compliance Risk Management Lifecycle (2026)*

HOW IT WORKS

- 1 Policies** set the rules; **assessments** check they are followed.
- 2 Training records** show what staff have learned.
- 3 Evidence** leads to **findings** when something is missing.
- 4 Remediation records** show each fix and feed back into policy (§ 164.316).

TEMPLATE IN ACTION

Completed sample · Sunshine Dental Group (fictional data)

COMPLIANCE DOCUMENT PACKAGE

PKG-2026-01 · v1.0

Package owner **Anèl Henning**

Retention **Six years** **1**

A · GOVERNANCE **2**

- ✗ Security official designation
- ✗ Vendor / BA agreements
- Incident-response plan

B · RISK AND ASSESSMENT

- ✓ Risk analysis
- ✓ Risk register v1.0
- ✓ Gap analysis report

C · WORKFORCE AND ACCESS

- ✗ Awareness training records
- ✓ Access-review records
- Termination evidence

D · TECHNICAL

- ✗ Audit-log review evidence
- Backup restore test
- ✓ Access-control script output

E · DOCUMENT-CONTROL REGISTER **3**

ID	Document	Owner	Version	Next review
DC-05	Risk Register Assessment	IT Vendor	1.0	[DATE]
DC-09	Account Lifecycle Review	Office Mgr	1.0	Quarterly

✓ on file · • partial · ✗ missing — each ✗ maps to a tracker item **4**

READ THE CALLOUTS

- 1 Six-year retention** is printed on the package itself.
- 2 Four evidence groups** mirror how auditors request proof.
- 3 The register** versions every document and its next review.
- 4 Every gap** already has an owner in the tracker.

WHEN IT FAILS

\$16M

record HHS settlement

Anthem: weak links in the compliance cycle

In 2015, phishing emails gave attackers access to Anthem's systems and health plan data for 79 million people. HHS found Anthem had not conducted an enterprise-wide risk analysis and lacked sufficient activity review and controls. It paid a then-record \$16 million settlement (HHS, 2018).

REFERENCES

- Arthur Andersen LLP v. United States, 544 U.S. 696 (2005).
- Block, Inc. (2022, April 4). *Form 8-K: Current report*. U.S. Securities and Exchange Commission.
- Committee of Sponsoring Organizations of the Treadway Commission. (2013). *Internal control—Integrated framework: Executive summary*.
- Cooper, C. (2008). *Extraordinary circumstances: The journey of a corporate whistleblower*. Wiley.
- ISACA. (2022). [Add full title from your original source list — cited for the audit plan definition].
- Merck & Co. v. ACE American Insurance Co., No. A-1879-21 (N.J. Super. Ct. App. Div. May 1, 2023).
- National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments* (SP 800-30 Rev. 1).
- National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (SP 800-53 Rev. 5).
- National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*.
- Office of the Comptroller of the Currency. (2020b, October 8). *OCC assesses \$60 million civil money penalty against Morgan Stanley*.
- Public Company Accounting Oversight Board. (n.d.-a). *AS 2201: An audit of internal control over financial reporting*.
- Public Company Accounting Oversight Board. (n.d.-b). *AS 2315: Audit sampling*.
- Public Company Accounting Oversight Board. (n.d.-c). *AS 1105: Audit evidence*.
- Sarbanes-Oxley Act of 2002, Pub. L. No. 107-204, 116 Stat. 745 (2002).
- Security Standards: Administrative Safeguards, 45 C.F.R. § 164.308 (2024).
- Security Standards: Documentation, 45 C.F.R. § 164.316 (2024).
- Security Standards: Technical Safeguards, 45 C.F.R. § 164.312 (2024).
- U.S. Department of Health and Human Services. (2018, October 15). *Anthem pays OCR \$16 million in record HIPAA settlement*.
- U.S. Department of Health and Human Services. (2020, September 25). *Health insurer pays \$6.85 million to settle data breach*.
- U.S. Government Accountability Office. (2018). *Data protection: Actions taken by Equifax and federal agencies* (GAO-18-559).
- U.S. Securities and Exchange Commission. (2013, October 16). *SEC charges Knight Capital with violations of market access rule*.
- U.S. Securities and Exchange Commission. (2018, April 24). *Altaba, formerly known as Yahoo!, charged with failing to disclose breach*.
- U.S. Securities and Exchange Commission. (2022, September 20). *Morgan Stanley Smith Barney charged with failing to protect PII*.
- U.S. Senate Committee on Commerce, Science, and Transportation. (2014). *A “kill chain” analysis of the 2013 Target data breach*.

**Anèl Henning · Compliance Analyst**

All examples use fictional Sunshine Dental Group data. No real patient or company information is shown.

linkedin.com/in/anel-henning-quantum
[anelhenning2-collab.github.io/portfolio](https://github.com/anelhenning2-collab/portfolio)